Cibersegurança Moderna
Mais é Sempre Melhor?

GRUPO DE OPOSIÇÃO

Cibersegurança é necessária. O problema é a premissa de que mais tecnologia sempre equivale a mais proteção.

A adoção indiscriminada de soluções complexas gera custos, ruídos e riscos operacionais que frequentemente superam seus benefícios teóricos.

Pilares da Oposição



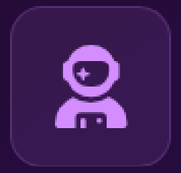
1. Custos



2. Riscos Operacionais



3. Complexidade



4. A barreira Humana



Pilar 1: Custos

O Paradoxo do Investimento Infinito e a Teoria Econômica da Segurança.

Fundamentação Acadêmica

A Ilusão do Investimento Infinito

O artigo **"Integrating cost–benefit analysis into the NIST Cybersecurity Framework via the Gordon–Loeb Model"** (Journal of Cybersecurity, Oxford Academic) quebra o mito de que gastar mais resolve o problema.

O modelo econômico prova matematicamente que o investimento em segurança da informação possui retorno marginal decrescente.

> *"A pergunta correta não é 'Qual é a tecnologia mais avançada?', mas sim 'Qual investimento produz a proteção adequada ao nosso risco?'"*

Mecânica do Retorno Decrescente

O Ponto Ótimo de Investimento

O modelo de Gordon-Loeb demonstra que uma organização deve gastar apenas uma fração do prejuízo esperado de uma violação para proteger aquele conjunto de informações.

Existe um limite (geralmente em torno de 37% da perda esperada) a partir do qual cada dólar adicional investido em segurança gera menos de um dólar em benefício na redução do risco.

A Falácia do "Risco Zero"

Arquiteturas modernas (como implementações estritas de Zero Trust com múltiplas IAs acopladas) buscam incessantemente fechar 100% das brechas.

A teoria econômica prova que perseguir a segurança perfeita é irracional e financeiramente insustentável. O custo marginal de proteger os últimos 5% de vulnerabilidade é astronômico.

O Abismo das PMEs

Alvo Inatingível

O mesmo estudo reforça que a falta de recursos é o desafio primário para pequenas e médias empresas na adoção de frameworks modernos como o NIST.

Ao promover que "cibersegurança moderna requer dezenas de ferramentas integradas", a indústria cria um padrão que empresas menores nunca alcançarão.

> O resultado? Paralisação. Na tentativa de comprar soluções complexas (e falhar na implementação), abandona-se o básico bem feito que traria o maior custo-benefício.



Pilar 2: Riscos Operacionais

Sistemas que falham por excesso de alarme: A armadilha do SOC.

Evidência Científica

A Fadiga de Alertas (SOC)

De acordo com o paper **"Alert Fatigue in Security Operations Centres: Research Challenges and Opportunities"** (ACM Computing Surveys, 2025):

Plataformas modernas (SIEMs, XDRs) são configuradas para minimizar "falsos negativos" (não deixar passar nada). O efeito colateral é um dilúvio de dados.

> O uso de Machine Learning e heurísticas complexas contra ameaças variadas agrava o problema, inundando a tela do analista com falsos positivos constantes.

O Estudo USENIX Security

99%

FALSOS POSITIVOS

O "Lobo" Digital

O estudo qualitativo *"99% False Positives: A Qualitative Study of SOC Analysts' Perspectives"* documenta a realidade operacional das defesas modernas.

Quando 99 em cada 100 alertas investigados revelam ser atividades legítimas do ambiente, o problema deixa de ser uma falha técnica e passa a ser o excesso de ruído. Esse volume faz com que o analista ignore os avisos por padrão, gerando uma dessensibilização que abre margem para que ameaças reais passem despercebidas.

A tecnologia, ao tentar ser onipresente, sabota a própria defesa ao esgotar a capacidade humana de atenção.

A Reação Humana ao Ruído



Dessensibilização

Analistas condicionam-se a ignorar alertas, assumindo preventivamente que são alarmes falsos. O alerta real crítico é classificado como ruído.



Desconfiança

A equipe perde a confiança nas ferramentas bilionárias adquiridas pela empresa, desativando módulos avançados para conseguir trabalhar em paz.



Burnout Acelerado

O volume constante e a pressão geram esgotamento mental rápido, aumentando a rotatividade (turnover) em uma área que já carece de profissionais.



Pilar 3: Complexidade

A adição de tecnologia aumenta exponencialmente as chances de erro.

Complexidade é Inimiga da Segurança

"Mais complexidade significa mais pessoas envolvidas, mais peças, mais interações e mais erros no design... mais lugares onde inseguranças ocultas podem ser encontradas."

— Bruce Schneier & Anthony Vance, Editorial na MIS Quarterly (2025)

Este é o argumento definitivo na área de Sistemas de Informação: a própria essência da cibersegurança moderna (adicionar mais camadas, integrações e agentes autônomos) viola o princípio fundamental do design seguro.

Novas Camadas, Novas Brechas

A ilusão do Zero Trust: Exige orquestração perfeita entre dezenas de componentes. Uma falha de configuração na política de acesso abre portas críticas.

IA como vetor de ataque: Modelos integrados de defesa moderna estão sujeitos a ataques adversariais (data poisoning, prompt injection).

Integrações via APIs: Ferramentas precisam conversar entre si. Cada chave de API, webhook ou agente de integração é um novo ponto de falha cobiçado por atacantes.

A Base Teórica: Incentivos Perversos

Why Information Security is Hard (2001)

O clássico paper de Ross Anderson, Cambridge (com mais de 3.000 citações), estabelece que a insegurança não é apenas uma falha técnica, mas um problema econômico e de incentivos.

Fabricantes de software (vendors) são incentivados pelo mercado a lançar ferramentas complexas e cheias de "features" rapidamente, terceirizando o risco de configuração para o cliente final.

O Problema na Prática Hoje

A indústria vende **"balas de prata"** tecnológicas (como XDR impulsionado por IA). O incentivo do vendedor é vender mais complexidade.

O custo de gerenciar essa complexidade (manutenção, tuning de regras, treinamento) recai sobre a empresa compradora, que raramente possui os recursos econômicos para fazê-lo de forma perfeita, resultando em adoções mal configuradas.



Pilar 4: A Barreira Humana

A Dificuldade de Adoção não é técnica, é a falta de pessoas.

Pesquisa do Setor - ISC2

O ISC2 Cybersecurity Workforce Study 2024 estimou uma lacuna global de aproximadamente 4,8 milhões de profissionais de cibersegurança, evidenciando a dificuldade do setor em suprir a demanda por profissionais qualificados.

Em complemento, o ISC2 Cybersecurity Workforce Study 2025 — pesquisa global com 16.029 profissionais de cibersegurança — mostra que 88% dos participantes relataram que a escassez de habilidades já causou consequências significativas em suas organizações.

4.8M

PROFISSIONAIS EM FALTA

A Tecnologia Ociosa

A Desconexão Prática

Não faz sentido estratégico adquirir a arquitetura mais moderna e automatizada se não há profissionais qualificados disponíveis no mercado para operá-la, calibrá-la e mantê-la.
Ferramenta avançada sem equipe preparada pode se tornar um “elefante branco digital”: cara, complexa e subutilizada. Pode gerar logs que ninguém analisa, alertas que sobrecarregam a equipe e, na prática, oferecer pouca resposta efetiva aos incidentes.

Tool Sprawl

Tool Sprawl é o acúmulo excessivo de ferramentas e soluções de segurança dentro de uma organização, geralmente causado pela adoção de diferentes produtos para atender a ameaças ou necessidades específicas,a adição contínua de novas soluções aumenta a quantidade de painéis, agentes e alertas que precisam ser administrados e integrados, elevando a complexidade operacional.

Nesse contexto, nem sempre a adoção da ferramenta mais moderna é a melhor escolha. Para organizações com recursos limitados, especialmente pequenas empresas, pode ser mais adequado priorizar higiene básica de segurança, como atualizações, backups, autenticação multifator, controle de acesso e gerenciamento de senhas, antes de investir em arquiteturas e ferramentas mais complexas.

A Alternativa Eficaz

Arquiteturas Complexas

Demandam orçamentos imensos, geram tool sprawl, fadiga severa de alertas, exigem profissionais raros (e caros) e expandem a superfície técnica de erros de configuração.

Higiene Básica de Segurança

Gestão de patches contínua, backups testados e imutáveis, controle de acesso restrito (senhas fortes + MFA universal) e treinamento prático de usuários. Resolve a imensa maioria dos vetores reais com fração do custo operacional e cognitivo.

Referências

1 GORDON, Lawrence A.; LOEB, Martin P.; ZHOU, Lei. **Integrating cost–benefit analysis into the NIST Cybersecurity Framework via the Gordon–Loeb Model.** Oxford University Press, 2020. Disponível em: https://academic.oup.com/cybersecurity/article/6/1/tyaa005/5813544. Acesso em: 14 ago. 2026

2 TARIQ, Shahroz; CHHETRI, Mohan Baruwal; NEPAL, Surya; PARIS, Cecile. **Alert Fatigue in Security Operations Centres: ResearchChallenges and Opportunities.** ACM Digital Library, 2025. Disponível em: https://dl.acm.org/doi/full/10.1145/3723158. Acesso em: 14 ago. 2026

3 ANDERSON, Ross. **Why information security is hard - an economic perspective.** IEEE Xplore, 2001. Disponível em: https://ieeexplore.ieee.org/document/991552. Acesso em: 14 ago. 2026

Referências

4 **CYBERSECURITY Professionals Navigate Evolving Workplaces While Seizing New Opportunities.** ISC2, 2025. Disponível em: https://www.isc2.org/Insights/2025/12/2025-ISC2-Cybersecurity-Workforce-Study. Acessado em: 14 ago. 2026

5.SCHNEIER, Bruce; VANCE, Anthony. **"Complexity Is the Worst Enemy of Security": Studying Cybersecurity Through the Lens of Organizational Complexity. MIS Quarterly**, v. 49, n. 1, p. 205-210, 2025. Disponível em: https://doi.org/10.25300/MISQ/2025/49.1.075. Acesso em: 14 ago. 2026

6.ALAHMADI, Bushra A.; AXON, Louise; MARTINOVIC, Ivan. **99% False Positives: A Qualitative Study of SOC Analysts' Perspectives on Security Alarms**. 31st USENIX Security Symposium (USENIX Security 22), p. 2783-2800, 2022. Disponível em: https://www.usenix.org/system/files/sec22summer_alahmadi.pdf. Acesso em: 14 ago. 2026

Obrigado!